

Where the vulnerabilities already being exploited are concentrated

An AWS data lake provisioned 100% in Terraform over the public CISA KEV catalog, with a measured query cost.

Group g07 · CESAR School · 2026.2

Members: Bruno Ribeiro · Emanuel Eduardo · Igor Alves

Leonardo Amaral · Victor Guilherme · Vinícius Petribu

Scenario and business question

- CISA publishes the **KEV** catalog: vulnerabilities with **confirmed exploitation in real attacks** — not theoretical ones.
- Every security team faces the same scarcity: **more CVEs than capacity to patch**.
- The question that sets the remediation queue: **which vendors concentrate the exploited vulnerabilities of the last 12 months?**
- And the question that drives the architecture: **what does answering it cost in Athena?**

1,713

CVEs in the catalog
(catalogVersion 2026.09.16)

299

added in the last 12 months

118

distinct vendors in the window

Provisioned architecture

CISA KEV — public feed

JSON, no authentication, 1,727,984 bytes

▼ ingest.sh — 5 quality gates

S3 · eda262-g07-lake-raw

source document, byte-for-byte — proof of origin

▼ cleaned and typed → NDJSON

S3 · eda262-g07-lake-trusted

1,713 rows · 1,502,572 bytes

▼ schema declared in IaC

Glue Data Catalog · eda262_g07_kev

kev_vulnerabilities — 15 columns, no Crawler

▼

Athena WorkGroup · eda262-g07-wg

100 MB per-query cap, enforced at the WorkGroup

- **100% Terraform**, packaged as a module.
- Remote backend **S3 + DynamoDB**, with a workspace.
- Mandatory tags via the provider's **default_tags** — a new resource cannot forget them.
- **Zero Glue Crawlers**: the schema is reviewable code.

Grain: one row per CVE

- The grain is declared **in the catalog itself**, as a table parameter:

```
grain = "one row per cve_id"
```

- **Proven, not asserted:** a named query runs **count(*) – count(DISTINCT cve_id)** and must return 0.
- Alternative evaluated and **rejected with a number:** a grain per (CVE, product).
- **214 of 1,713 product** values (12.5%) carry an ambiguous separator.

```
"NetScaler ADC and NetScaler Gateway" → 2 products  
"Community Edition and Enterprise Edition" → 1 product
```

No deterministic rule separates the two cases. Splitting on the separator would inflate the product count through a parsing artifact — in the very indicator the question measures.

1,713

rows in the trusted table

1,713

distinct cve_id

0

duplicates — the grain holds

From the raw layer to the trusted layer

PROBLEM MEASURED AT SOURCE	BEFORE	AFTER
Stray whitespace in vendor / product	18	0
"Known" / "Unknown" as text	360 / 1,353	boolean
"Yes" / "No" as text	55 / 1,658	boolean
cwes without a precomputed count	array	int
1 JSON object with a nested array	1 row	1,713 rows

Ingestion only publishes if the **5 gates** pass. The grain gate blocks the upload — data that violates the model never reaches the trusted layer.

WHY THIS IS NOT COSMETIC

- The value **"SimpleHelp "** (trailing space) appears in **4** records.
- Without **TRIM**, a future clean occurrence would create **two groups** in the GROUP BY.
- That is the difference between a correct ranking and a **silently wrong** one.

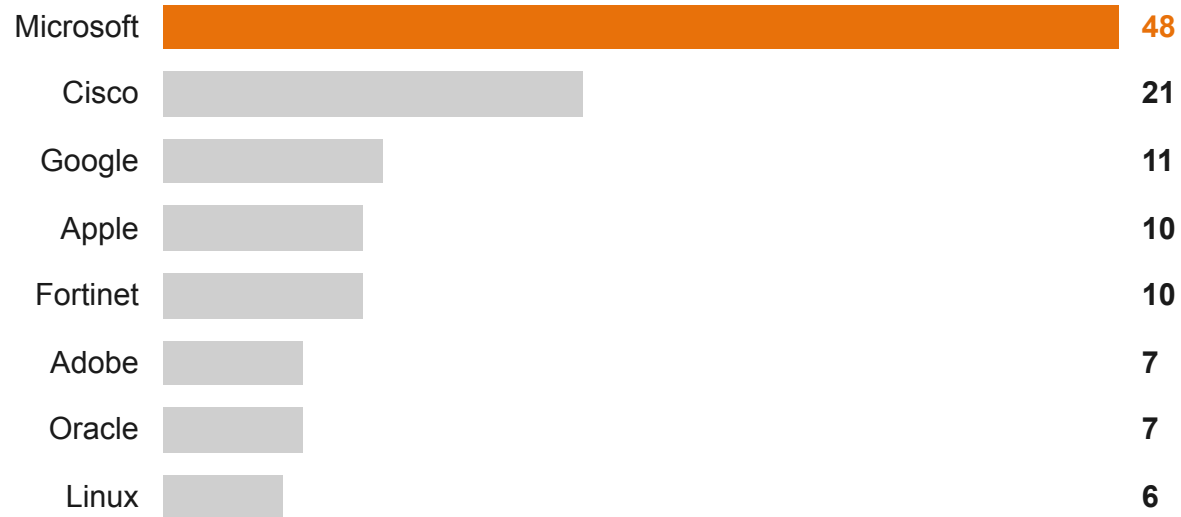
Schema declared in code, no Crawler

- The **15 columns** are declared in Terraform and rendered from **a single source of truth**.
- A Crawler costs **USD 0.073** per run (USD 0.44/DPU-hour, 10-minute minimum — list price).
- Against a stable schema it would pay **to rediscover what we already know** — and could drift types between runs.
- Schema as code costs **USD 0.00**, goes through **code review**, and fails at **plan**, not in production.

```
columns = [  
  { cve_id           string }  
  { vendor_project   string }  
  { product          string }  
  { date_added       string }  
  { is_known_ransomware_use boolean }  
  { requires_forensic_triage boolean }  
  { cwes             array<string> }  
  { cwe_count        int }  
  { catalog_version   string }  
  { ingested_at       string }  
  ...  
]
```

Dates stay **string** in ISO-8601: in NDJSON every value is text, and forcing **date** would turn a parse failure into a **silent NULL** — precisely in the 12-month filter.

The answer: concentration over the last 12 months



CVEs added to KEV in the last 12 months, by vendor. Base: 299 CVEs. Top 1 = 16% · top 5 = 33% · top 10 = 44%. Source: [docs/evidence/business-question-result.csv](#).

THE FINDING THAT REORDERS THE QUEUE

10% vs 43%

share linked to **ransomware**:

Microsoft (5 of 48) · Oracle (3 of 7)

Volume is **not** risk. Patching by rank alone treats Oracle as the seventh priority — when nearly half of its KEV entries have already been used in ransomware.

Measured query cost

MEASUREMENT	VALUE
Trusted table size	1,502,572 B
Volume scanned (measured)	3,005,144 B
Athena minimum billed	10,485,760 B
Volume actually billed	10,485,760 B
Price (us-east-1)	USD 5.00 / TB
Queries per USD 1.00	≈ 20,973

USD 0.00004768

cost per run of the business question

WHY WE DID NOT USE PARQUET

- The query scans **3.0 MB** and fits **3.5x** inside the 10 MB minimum billing unit.
- The scan is **2.00x the table**: the scalar subquery makes Athena read the data twice — only found by measuring.
- Parquet and partitioning would cut **bytes read** — and **not one cent** of the bill, which is already at the floor.
- Measured saving from the optimization: **USD 0.00**.
- It belongs to Part 2, once volume clears the floor — a decision by number, not by calendar.

Infrastructure discipline

- **Module + remote backend + workspace.** The **av1** workspace produces the mandated names; others get a suffix, because S3 bucket names are **global**.
- **The default workspace is blocked** by a precondition: it fails at plan, before creating any resource.
- **The SQL lives in Terraform** as a named query, and the script runs it **by ID** — what executes cannot drift from what was reviewed.
- **Teardown is verified, not assumed:** Terraform reports success even when it orphans a resource. We re-check all **5** against AWS afterwards.

COST GUARDRAIL

100 MB

per-query cap enforced at the WorkGroup — $\approx 70\times$ the current dataset

25

criteria in verifica.sh, with a PASSA / FALHA verdict each

0

orphaned resources tolerated after teardown

Every decision, one number

DECISION	THE NUMBER BEHIND IT
Grain: one row per CVE	1,713 / 1,713 · 0 duplicates
Per-product grain rejected	214 ambiguous (12.5%)
Cleaning in the trusted layer	18 → 0
Schema in IaC, no Crawler	15 columns · USD 0.073 avoided
Cost per query	USD 0.00004768
Parquet deferred to Part 2	USD 0.00 saving
Teardown without orphans	5 resources checked

NEXT PHASE

- Volume that **clears the billing floor** — only then do Parquet and partitioning have a measurable saving.
- **Idempotent** ingestion with partition backfill.
- Refined layer and per-layer permissions via **Lake Formation**.

Repository: eda262-projeto-g07

Evidence: docs/evidence/

Decisions: DECISIONS.md